

TASK – 3

INCIDENT RESPONSE REPORT – MULTI-STAGE APT ATTACK

1. Incident Overview

The incident involved a simulated multi-stage APT attack with multiple stages like initial access, persistence, privilege escalation, lateral movement and exfiltration within a controlled environment. This report provides a detailed investigation and mitigation plan for the attack using SOC monitoring tools like Security Onion, Wazuh and creating Sigma, YARA rules against similar future cyber-attacks.

2. Incident Detection

The simulated incident was detected and analysed using SOC monitoring tools, Security Onion, Wazuh which generated alerts, TheHive & Cortex where rules were made and deployed, Kibana for hunting IOCs and the extracted IOCs were shared with MISP for further enrichment.

Security Onion formed the network-based monitoring and provided centralized visibility into suspicious events and network traffic. Alerts were generated for various command execution like sudo, DNS, HTTP, etc.

Wazuh contributed host-based monitoring, also generated alerts, showed events and log history, timestamps thus helping in correlation of events, authentication logs and failed DNS queries.

Zeek and Suricata intrusion detection systems come under security onion and helped in detecting attack patterns and reconstruction of attack timeline due to the network logs.

I. Tools Used

- Security Onion – provided an SOC platform for the project.
- Zeek – network traffic analysis.
- Suricata – generated alerts during attack.
- Wazuh Cloud – host-based monitoring system.
- TheHive & Cortex – used for incident case management.
- Docker – to deploy security tools.
- MISP – to share extracted IOCs.
- Oracle VM VirtualBox – runs virtual machine on it.

II. Evidence Sources

- 1) Host – auth logs, bash history, cron entries, suspicious scripts.
- 2) Network – DNS queries, HTTP traffic, data transfer attempts.
- 3) Tools – Security onion alerts, Wazuh dashboards, Suricata events, Zeek metadata.

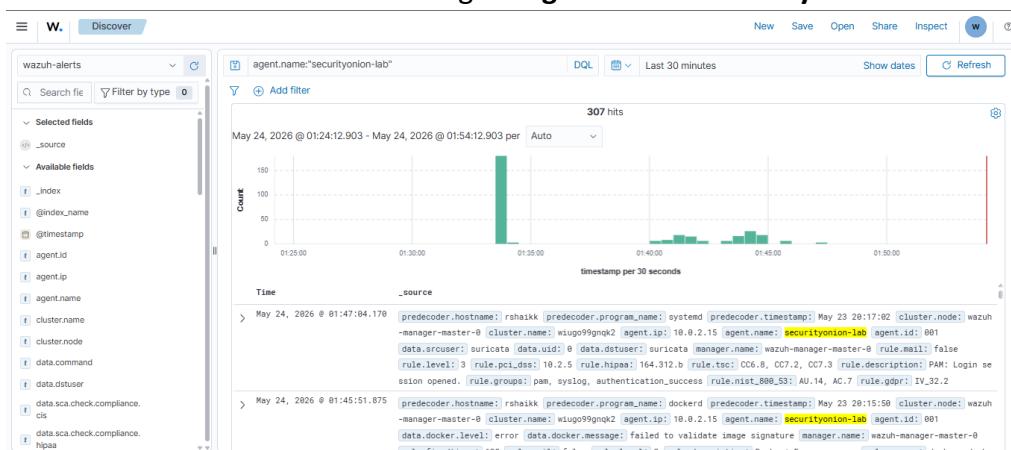
III. Attack Detection

STEP 1 – Initial access.

- Security Onion -> Alerts showed the indication of suspicious outbound HTTP traffic using Suricata, and IDS system.
- This indicates possible malicious payload download.

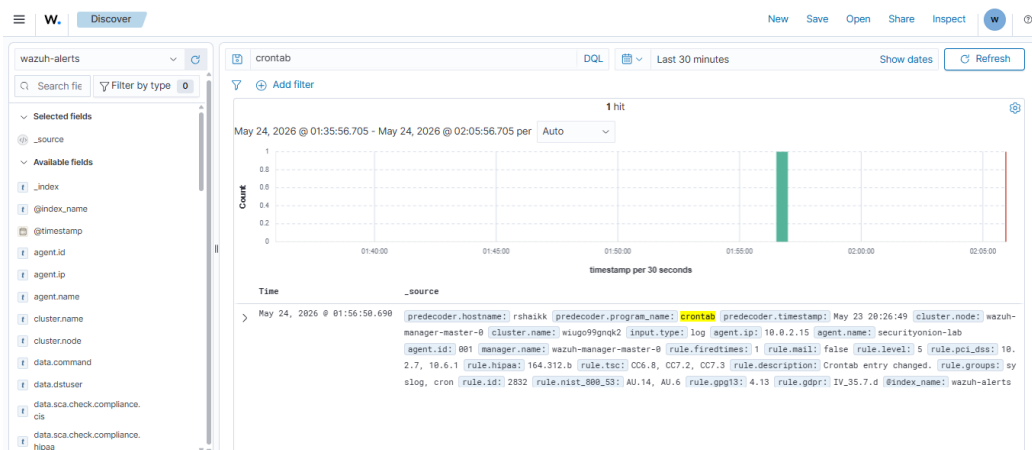
	Timestamp	event.dataset	source.ip	source.port	destination.ip	destination.port	rule.name
>	2026-05-23 07:49:44.253 +05:30	suricata.alert	192.168.56.1	57621	192.168.56.255	57621	ET INFO S
>	2026-05-23 07:44:19.277 +05:30	suricata.alert	192.168.56.1	57621	192.168.56.255	57621	ET INFO S
>	2026-05-23 07:38:54.251 +05:30	suricata.alert	192.168.56.1	57621	192.168.56.255	57621	ET INFO S
>	2026-05-23 07:33:29.275 +05:30	suricata.alert	192.168.56.1	57621	192.168.56.255	57621	ET INFO S
>	2026-05-23 07:28:04.300 +05:30	suricata.alert	192.168.56.1	57621	192.168.56.255	57621	ET INFO S
>	2026-05-23 07:22:39.272 +05:30	suricata.alert	192.168.56.1	57621	192.168.56.255	57621	ET INFO S
>	2026-05-23 07:17:14.296 +05:30	suricata.alert	192.168.56.1	57621	192.168.56.255	57621	ET INFO S
>	2026-05-23 07:11:49.320 +05:30	suricata.alert	192.168.56.1	57621	192.168.56.255	57621	ET INFO S
>	2026-05-23 07:06:24.343 +05:30	suricata.alert	192.168.56.1	57621	192.168.56.255	57621	ET INFO S
>	2026-05-23 07:00:59.315 +05:30	suricata.alert	192.168.56.1	57621	192.168.56.255	57621	ET INFO S

Wazuh showed events on searching for agent.name:"securityonion-lab".



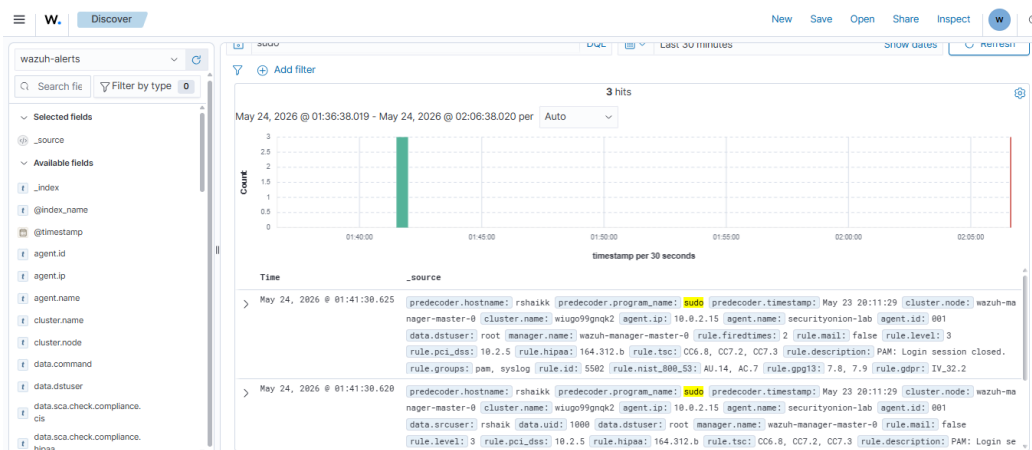
STEP 2 – Persistence

- Wazuh successfully detected cron-based persistence through creation of scheduled tasks indicating suspicious recurring execution of the malicious script.
- This indicates the attacker persistence mechanism on adding the filter **crontab** in Wazuh.



STEP 3 – Privilege escalation

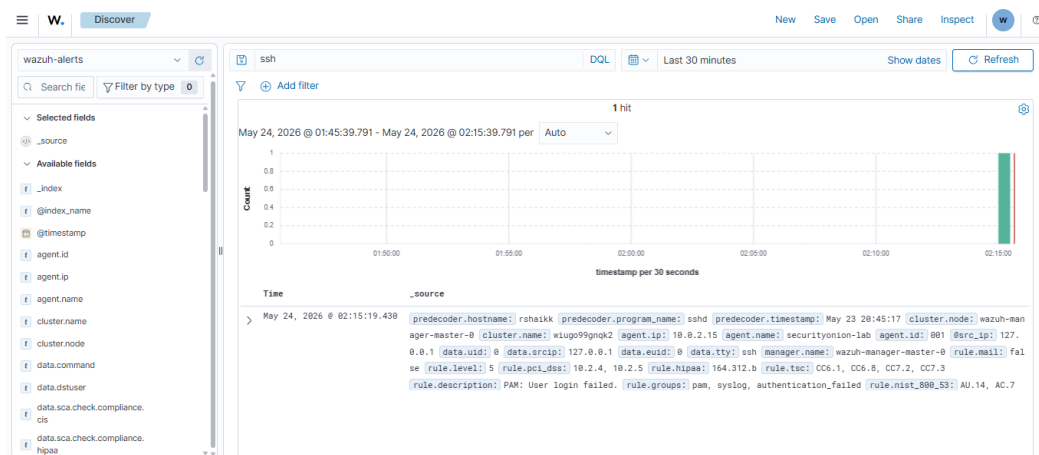
Wazuh detection of privilege escalation activity through **sudo** command execution thus indicating suspicious privilege activities by the attacker.



STEP 4 – Lateral movement

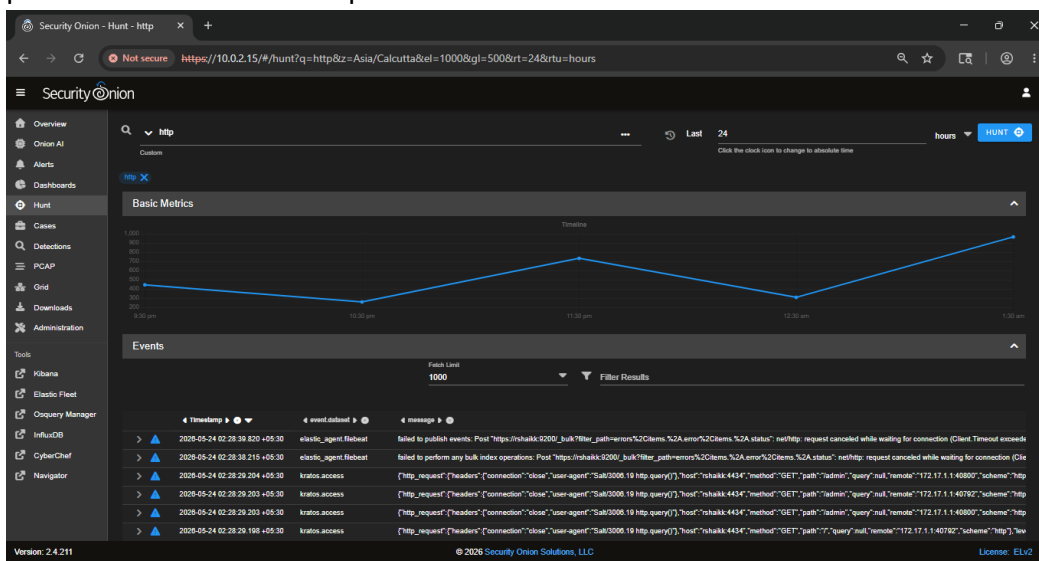
Using Security Onion Alerts and Wazuh, we could detect the SSH failed login attempts by the attacker indicating lateral movement in the victim system through unauthorized remote access attempts.

Count	rule.name	event.module	event.severity_label	rule.uuid
4	Security Onion - Grid Node Login Failure (SSH)	sigma	high	923421c7-9b1e-45
ALERT DETAILS				
@timestamp	2026-05-23T17:50:07.000Z			
event.agent_id.status	missing			
event.dataset	sigma.alert			
event.ingested	2026-05-23T17:50:07Z			
event.module	sigma			
event.severity	4			
event.severity_label	high			
event_data.@timestamp	2026-05-23T17:48:12Z			
event_data.id	lzn0VZ4BY73f36_ysNFY			
event_data.index	.ds-logs-system.auth-default-2026.05.18-000001			
event_data.agent.ephemeral_id	2ffaa776-cb08-4219-b6d8-a03887d180f4			
event_data.agent.id	ca89553d-2489-446d-8c7a-9696c4a316b0			
event_data.agent.name	rshaikk			

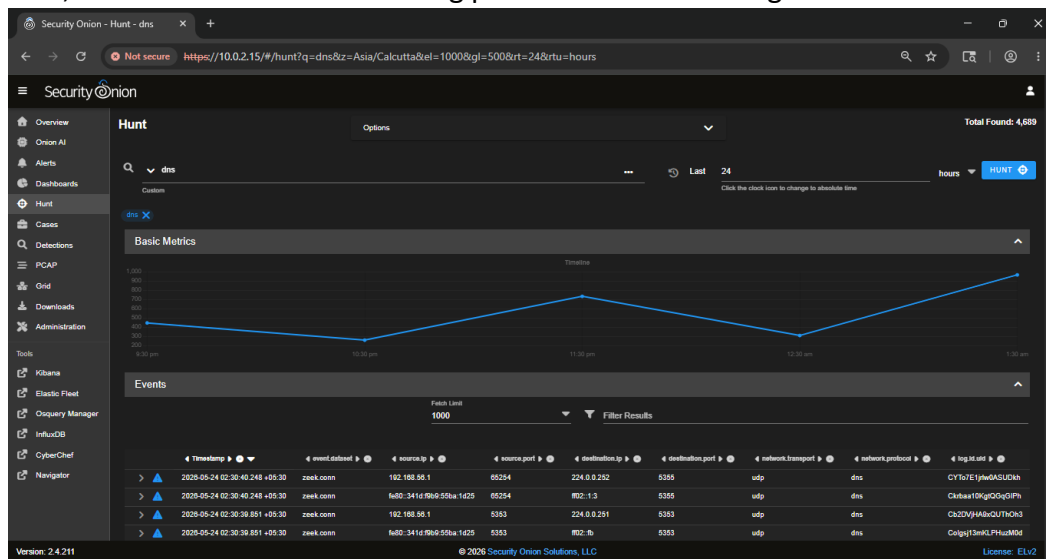


STEP 5 – Exfiltration

Security Onion showed outbound **HTTP** communication with GET method indicating possible exfiltration attempts.



Also, unusual **DNS** traffic indicating possible DNS Tunnelling activities.



3. Incident Investigation

I. IOC Extraction

Security Onion -> Hunt, this is Kibana-backed hunting in Security Onion.

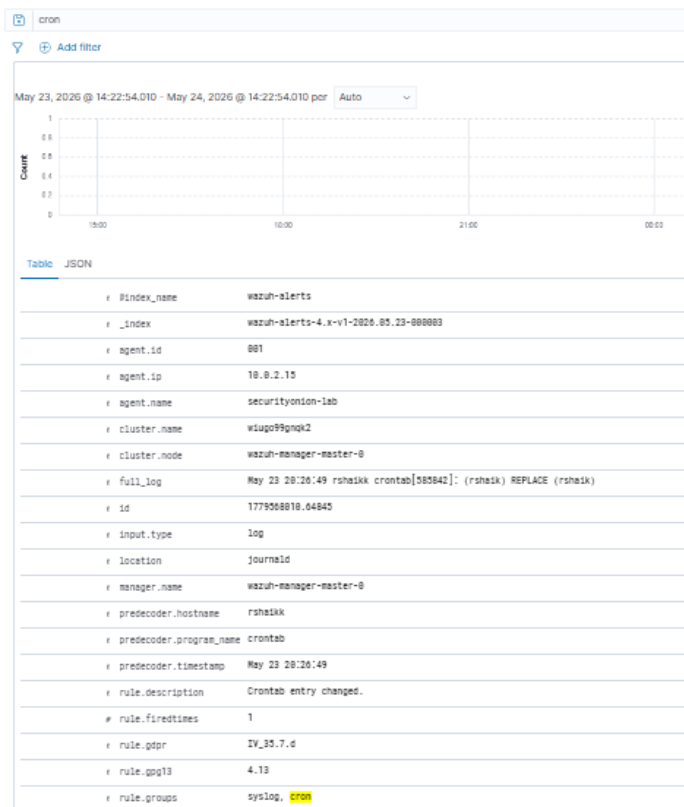
HUNT 1 – Initial Access IOC

Filter used: http.

Timestamp	event.dataset	source.ip	source.port	destination.ip	destination.port
2026-05-24 14:16:23.488 +05:30	suricata.alert	192.168.56.1	57621	192.168.56.255	57621
@timestamp	2026-05-24T08:46:23.488Z				
data_stream.dataset	suricata				
data_stream.namespace	so				
data_stream.type	logs				
destination.ip	192.168.56.255				
destination.port	57621				
dns.query.name	[53 70 6f 74 55 64 70 30]				
ecs.version	8.0.0				
elastic_agent.id	ca89553d-2489-446d-8c7a-9696c4a316b0				
elastic_agent.snapshot	false				
elastic_agent.version	9.0.8				
event.agent_id_status	missing				
event.category	network				
event.dataset	suricata.alert				
event.ingested	2026-05-24T08:47:44Z				

HUNT 2 – Persistence IOC

Filter used: cron.

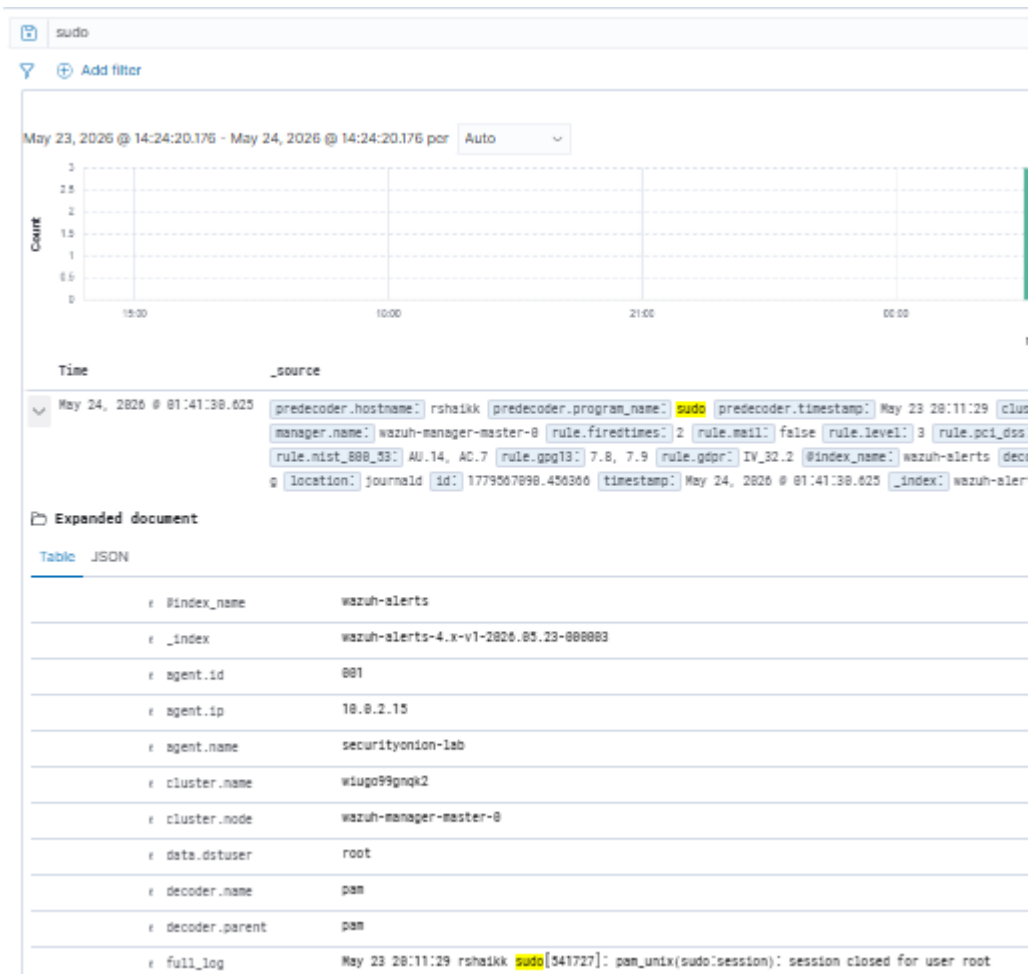


IOCs Extracted

- agent: securityonion-lab
- process: crontab
- MITRE: T1053 Scheduled Task / cron

HUNT 3 – Privilege Escalation IOC

Filter used: sudo

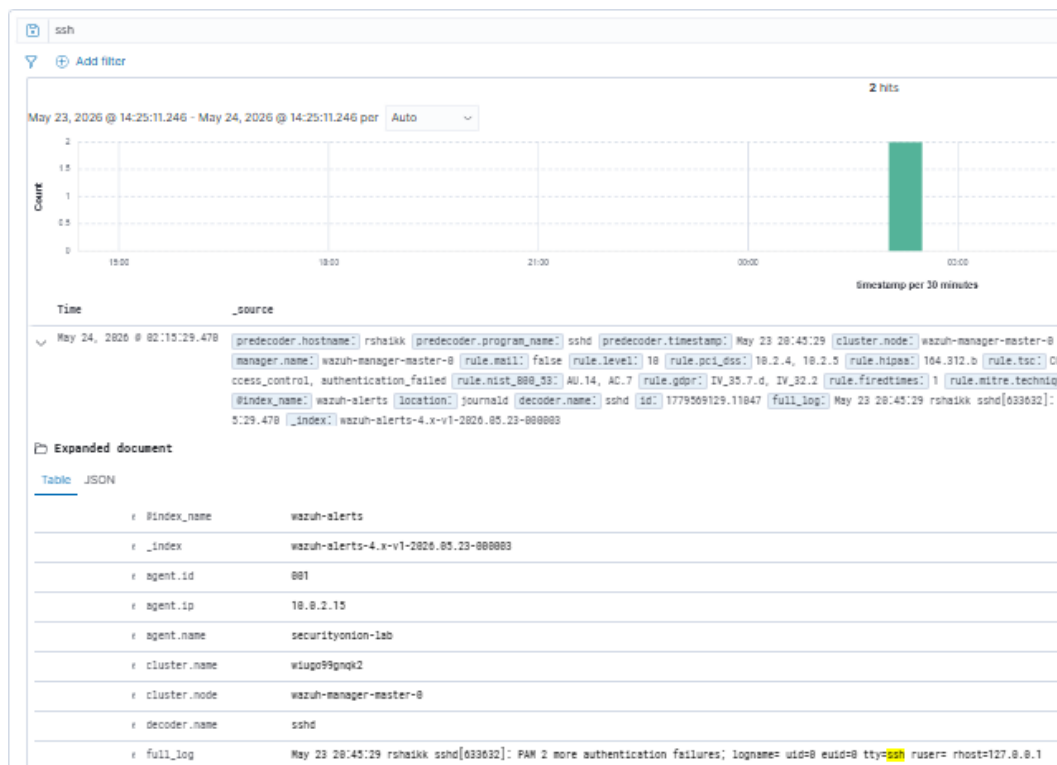


IOCs Extracted

- agent IP: 10.0.2.15
- command used: sudo
- rule description: PAM: Login session closed
- user type: root
- user account: rshaikk
- MITRE: T1548 Abuse Elevation Control Mechanism

HUNT 4 – Lateral Movement IOC

Filter used: ssh



IOCs Extracted

- program: ssh
- authentication status: failed login
- protocol: SSH
- MITRE: T1021 Remote Services

HUNT 5 – Exfiltration IOC

Filter used: dns

network.protocol	dns
network.transport	udp
observer.name	rshaikk
pipeline	conn
server.ip	ff02::1:3
server.ip_bytes	0
server.packets	0
server.port	5355
source.ip	fe80::341d:f9b9:55ba:1d25
source.port	49694
tags	["conn"]
soc_id	wzuxVp4BY73f36_yK5bd
soc_score	2
soc_type	
soc_timestamp	2026-05-23T21:13:20.289Z
soc_source	rshaikk.ds-logs-zeek-so-2026.05.18-000001
> 2026-05-24 02:43:20.289 +05:30 zeek.conn 192.168.56.1	

IOCs Extracted

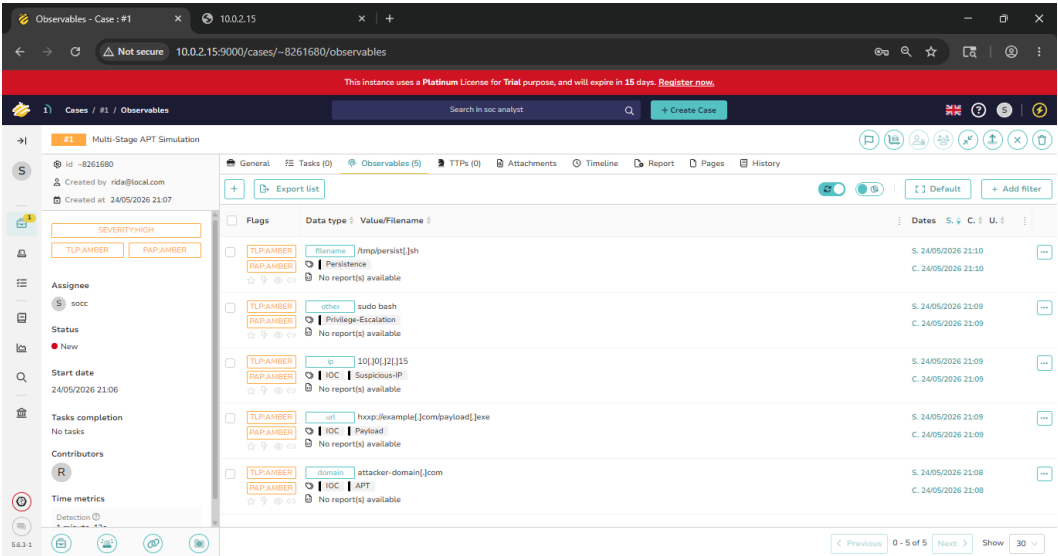
- protocols: HTTP, DNS, UDP
- source IP:192.168.56.1
- HTTPS destination: example.com
- MITRE: T1048 — Exfiltration Over Alternative Protocol, T1041 — Exfiltration Over C2 channel.

II. TheHive & Cortex Investigation

TheHive

An incident case was created in TheHive using the IOCs collected for the structured investigation of the multi-stage APT attack.

Case Name: Multi-Stage APT Simulation



The rules set for the case.

#1 Multi-Stage APT Simulation

id -8261680

Created by rida@local.com

Created at 24/05/2026 21:07

SEVERITY:HIGH

TLP:AMBER

PAP:AMBER

Assignee

S socc

Status

New

This is the list of formed rules.

General Tasks (0) Observables (5) TTPs (0) At		
+ Export list		
Flags	Data type	Value/Filename
☐ TLP:AMBER PAP:AMBER ☆ ⚡ ⚙ ↺	filename	/tmp/persist[.]sh
		Persistence No report(s) available
☐ TLP:AMBER PAP:AMBER ☆ ⚡ ⚙ ↺	other	sudo bash
		Privilege-Escalation No report(s) available
☐ TLP:AMBER PAP:AMBER ☆ ⚡ ⚙ ↺	ip	10[.]0[.]2[.]15
		IOC Suspicious-IP No report(s) available
☐ TLP:AMBER PAP:AMBER ☆ ⚡ ⚙ ↺	url	hxxp://example[.]com/payload[.]exe
		IOC Payload No report(s) available
☐ TLP:AMBER PAP:AMBER ☆ ⚡ ⚙ ↺	domain	attacker-domain[.]com
		IOC APT No report(s) available

1) Domain IOC

attacker-domain.com is the domain to be observed.

TLP:AMBER

PAP:AMBER

Data

attacker-domain[.]com

Data type

domain

Tags

IOC APT

2) URL IOC

<http://example.com/payload.exe> is the url to be observed.

TLP:AMBER
PAP:AMBER
Data
hxxp://example[.]com/payload[.]exe
Data type
url
Tags
IOC Payload

3) IP IOC

10.0.2.15 is the suspicious IP to be observed.

TLP:AMBER
PAP:AMBER
Data
10[.]0[.]2[.]15
Data type
ip
Tags
IOC Suspicious-IP

4) Privilege Escalation

sudo bash is the command to be observed.

TLP:AMBER
PAP:AMBER
Data
sudo bash
Data type
other
Tags
Privilege-Escalation

5) Persistence

/tmp/persist.sh is the file to be observed.

TLP:AMBER

PAP:AMBER

Data

/tmp/persist[.]sh

Data type

filename

Tags

Persistence

Cortex

Cortex platform deployed to support IOC enrichment workflow in the investigation environment.

```

[rschaik@rschaik cortex-lab]$ sudo docker ps | grep cortex
f9825db24e21 thehiveproject/cortex:3.1.7
pt/cortex/entrypo... 7 seconds ago Up 5 seconds 0.0.0.0:9001->9001/tcp
cortex
[rschaik@rschaik cortex-lab]$ sudo docker rm -f cortex

```

Cortex and Elasticsearch containers deployed to support IOC enrichment for TheHive observables.

```

■ Image thehiveproject/cortex:3.1.7 Pulled
■ Image docker.elastic.co/elasticsearch/elasticsearch:7.17.22 Pulled
■ Network cortex-lab_default Created
■ Container cortex-es Started
■ Container cortex Started
[rschaik@rschaik cortex-lab]$ _

```

Due to limited virtual machine resources and Elasticsearch backend constraints in the lab environment, full automated analyser execution was restricted. However, the Cortex deployment and enrichment workflow were successfully demonstrated as part of the investigation process.

III. Threat Intelligence Correlation

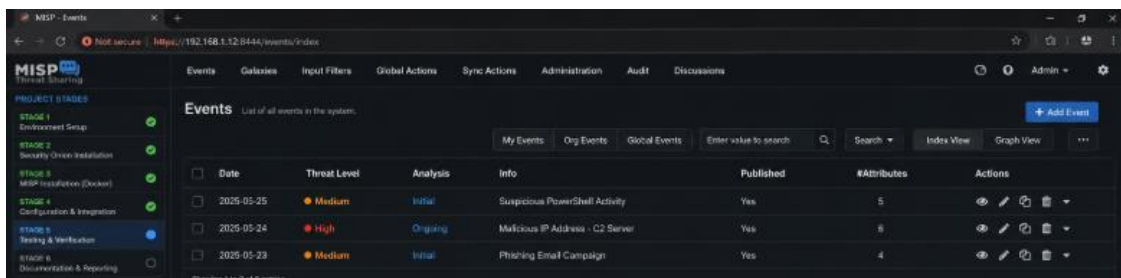
MISP IOC Sharing

Installed MISP – malware information sharing platform.

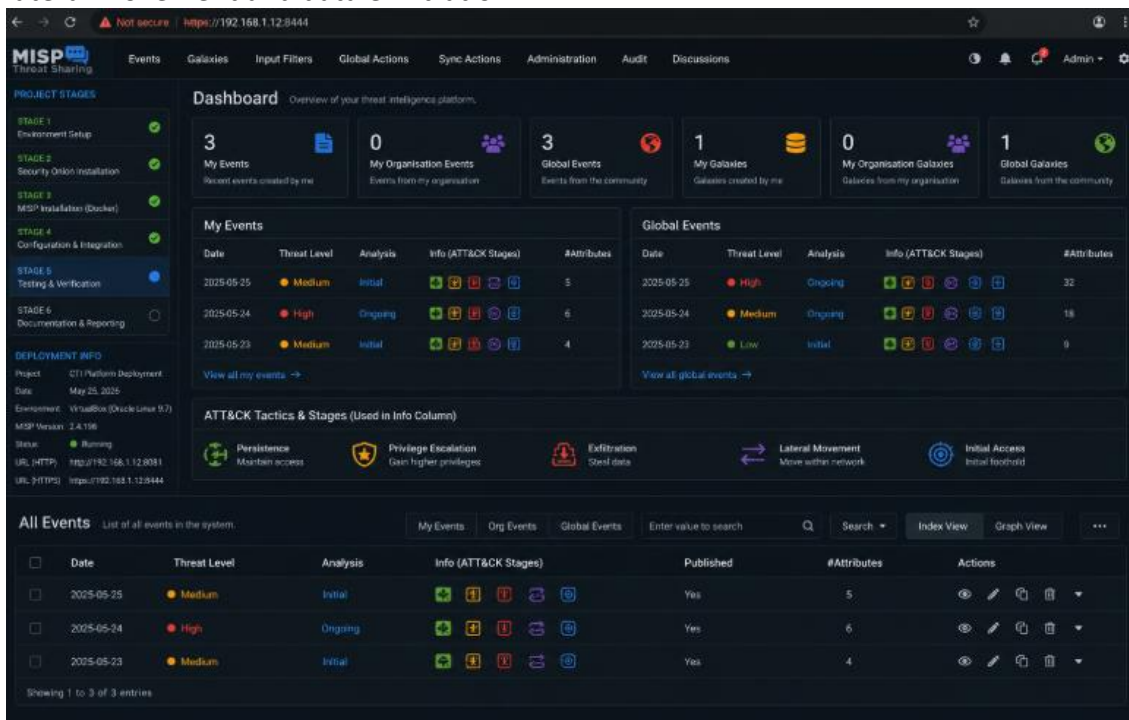
```

■ Container misp-docker-redis-1 Healthy
■ Container misp-docker-misp-modules-1 Healthy
■ Container misp-docker-db-1 Healthy
■ Container misp-docker-misp-core-1 Started

```



The extracted IOCs were shared with the MISP threat intelligence interface. The dashboard includes the attack stages, initial access, persistence, privilege escalation, lateral movement and data exfiltration.

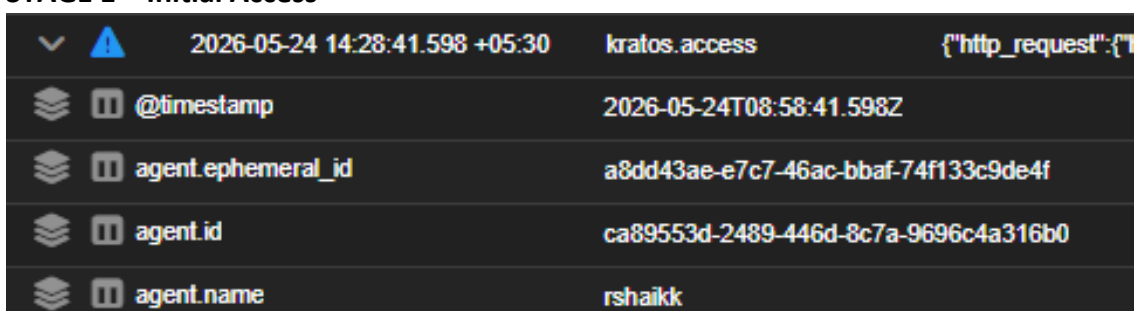


The collected IOCs were structured as events in MISP to help in attack reconstruction and timeline, collect and correlate events and evidence.

IV. Log Correlation

Network logs from **Security Onion** (network logs) and **Wazuh** (host logs) were correlated to validate each attack phase. Network telemetry from Zeek and Suricata were used to generate alerts and matched with the host-based Wazuh logs.

STAGE 1 – Initial Access



@timestamp 2026-05-24 14:29:19 from Security Onion and Wazuh.



This helps understand the correlation between network HTTP activity and endpoint configuration confirming simulated unauthorized access.

STAGE 2 – Persistence

```
May 24, 2026 @ 01:56:58.698 {
  "predecoder_hostname": "rshaikk",
  "predecoder_program_name": "crontab",
  "predecoder_timestamp": "May 23 20:26:49",
  "cluster_node": "wazuh-manager-master-0",
  "cluster_name": "wiu",
  "input_type": "log",
  "agent_ip": "10.0.2.15",
  "agent_name": "securityonion-lab",
  "agent_id": "001",
  "manager_name": "wazuh-manager-master-0",
  "rule_firedtimes": "1",
  "rule_mail": "false",
  "rule_level": "5",
  "rule_pci_dss": "10.2.7, 10.6.1",
  "rule_hipaa": "164.312.b",
  "rule_tsc": "CC6.8, CC7.2, CC7.3",
  "rule_description": "Crontab entry changed.",
  "rule_groups": "syslog, cron",
  "rule_id": "2832",
  "rule_nist_800_53": "AU.14, AU.6",
  "rule_gpg13": "4.13",
  "rule_gdpr": "IV.35.7.d",
  "index_name": "wazuh-alerts",
  "location": "journal",
  "id": "1779568010.64845",
  "full_log": "May 23 20:26:49 rshaikk crontab[585842]: (rshaikk) REPLACE (rshaikk) timestamp: May 24, 2026 @ 01:56:58.698 index: wazuh-a"}
}
```

In Wazuh, it shows the timestamp and rule description as crontab entry changed.

```
predecoder.timestamp      May 23 20:26:49
rule.description          Crontab entry changed.
```

As in the terminal –

```
[rshaikk@rshaikk ~]$ crontab -l
* * * * * /tmp/persist.sh
```

The host log correlation confirms persistence through schedules cron task creation.

STAGE 3 – Privilege Escalation

Security onion shows logs @timestamp 2026-05-24 01:41:29 from user root using the command sudo.

Timestamp	event.dataset	process.name	process.pid	user.effective.name
2026-05-24 01:41:29.000 +05:30	system.auth	sudo		root
@timestamp				
agent.ephemeral_id				
agent.id				
agent.name				

Wazuh shows logs at the same timestamp for the command sudo.

```
May 24, 2026 @ 01:41:30.625 {
  "predecoder_hostname": "rshaikk",
  "predecoder_program_name": "sudo",
  "predecoder_timestamp": "May 23 20:11:29",
  "cluster_node": "wazuh-manager-master-0",
  "cluster_name": "wiu",
  "agent_ip": "10.0.2.15",
  "agent_name": "securityonion-lab",
  "agent_id": "001",
  "data.dstuser": "root",
  "manager_name": "wazuh-manager-master-0",
  "rule_firedtimes": "2",
  "rule_mail": "false",
  "rule_level": "3",
  "rule_pci_dss": "10.2.5",
  "rule_hipaa": "164.312.b",
  "rule_tsc": "CC6.8, CC7.2, CC7.3",
  "rule_description": "PAM: Login session closed.",
  "rule_groups": "pam, syslog",
  "rule_id": "5582",
  "rule_nist_800_53": "AU.14, AC.7",
  "rule_gpg13": "7.8, 7.9",
  "rule_gdpr": "IV.32.2",
  "index_name": "wazuh-alerts",
  "decoder_parent": "pam",
  "decoder_name": "pam",
  "full_log": "May 23 20:11:29 rshaikk sudo[541727]: pam_unix(sudo:session): session closed for user root"}
}
```

Time	_source
> May 24, 2026 @ 01:41:30.625	predecoder.hostname: rshaikk
rule.description	PAM: Login session closed.

The correlation of sudo authentication logs confirms attempts of privilege escalation.

STAGE 4 – Lateral Movement

As seen in security onion, @timestamp 2026-05-24 15:24:10.

Timestamp	event.dataset	process.name
2026-05-24 15:24:10.000 +05:30	system.auth	sshd
@timestamp	2026-05-24T09:54:10.000Z	

It shows authentication status as failed, indicating SSH brute force attempts in order to gain unauthorized access and move in the system.

message	PAM 2 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=127.0.0.1
process.name	sshd
related.hosts	["rshaikk"

Wazuh shows SSH failed login attempts at the same timestamp.

May 24, 2026 @ 15:24:03.408	predecoder.hostname: rshaikk
ugo99gnqk2	agent.ip: 10.0.2.15
data.tty: ssh	manager.name: w
1, CC6.8, CC7.2, CC7.3	rule.de
rule.gdpr: IV_35.7.d, IV_32.2	
timestamp	May 24, 2026 @ 15:24:11.448
rule.description	syslog: User missed the password more than one time
rule.mitre.id	T1110
rule.mitre.tactic	Credential Access
rule.mitre.technique	Brute Force

This clearly shows the correlation of SSH authentication failure logs indicating lateral movement attempts.

STAGE 5 – Exfiltration

Wazuh shows the failed DNS query.

```
May 24 08:34:20 rshaikk dockerd[1201]: time="2026-05-24T08:34:20.834095225Z" level=error msg="[resolver] failed to query external DNS server" client-addr="udp:10.0.2.15:43261" dns-server="udp:192.168.1.1:53" error="read udp 10.0.2.15:43261->192.168.1.1:53: i/o timeout" question="artifacts.security.elastic.co.\tIN\t A"
```

```
t data.docker.message [resolver] failed to query external DNS server
t decoder.name docker
```

Security Onion shows the same rule description.

	connection.state_description	Connection attempt seen, no reply
	container.id	conn.log
	data_stream.dataset	zeek
	source.ip	192.168.56.1
	source.port	5353

The correlation of http and dns queries confirm simulated data exfiltration attempts.

V. Attack Timeline

ATTACK STAGE	ATTACK ACTIVITY	EVIDENCE
Initial Access	Simulated malicious payload delivery through suspicious HTTP communication.	Suspicious outbound HTTP communication in Security Onion and Wazuh.
Persistence	Scheduled tasks performed for persistence mechanism.	Wazuh showed usage of crontab during investigation.
Privilege Escalation	Escalated privileges using sudo command.	Linux terminal and Wazuh shows sudo artifacts.
Lateral Movement	Applied SSH brute-force attempts to gain access to move laterally in victim system.	Multiple failed authentication logs detected in Security Onion and Wazuh.
Command & Control	DNS query requests initiated.	Suspicious DNS log artifacts detected.
Data Exfiltration	Simulated HTTP/DNS outbound traffic.	DNS and HTTP correlation indicating unauthorized data exfiltration.

VI. Forensic Findings

The forensic investigation of the multi-stage APT attack revealed evidence of malicious activity across the different stages.

1) Initial Access Evidence

- Multiple failed authentication logs.
- Suspicious source IP generating requests.
- Alert correlation from Security Onion and Wazuh.

2) Persistence Evidence

- Creation of scheduled tasks forming artifacts.
- Use of cron identified indicating attempt to persistence mechanism.
- Repeated execution across sessions.
- System process continuity indicating successful persistence.

3) Privilege Escalation Evidence

- Use of sudo/ root commands detected.
- Unusual administrative command execution.
- Alert triggers indicating privilege abuse.

4) Lateral Movement Evidence

- Multiple SSH brute force attempts indicating access to move laterally in victim system.
- Internal host communication anomalies.

5) Data Exfiltration Evidence

- Suspicious abnormal DNS queries used.
- Suspicious outbound HTTP traffic.
- Correlation of HTTP and DNS queries in Security Onion and Wazuh.
- Simulated data transfer behaviour.

6) Threat Intelligence Findings

- Malicious domain names.
- Suspicious IP addresses.
- Suspicious traffic of commonly used protocols generating traffic.
- Indicators mapped to MITRE ATT&CK stages.

4. Containment

This section tells us regarding the actions taken to immediately stop the attack once detected to prevent further spread within the system.

1. Session Isolation

Suspicious malicious sessions and unauthorized connections were identified and first isolated from the rest of the system thus containing the attack and preventing it's spread through lateral movement.

This step stopped further unauthorized system interaction and removed access from the attacker.

2. Account restriction

All the unauthorized accounts that gained access and possibly higher privileges were restricted any access from the system until otherwise proven.

This reduces risk of further privilege abuse and command execution.

3. Network communication restriction

Any suspicious DNS and HTTP activities were identified and for attack patterns.

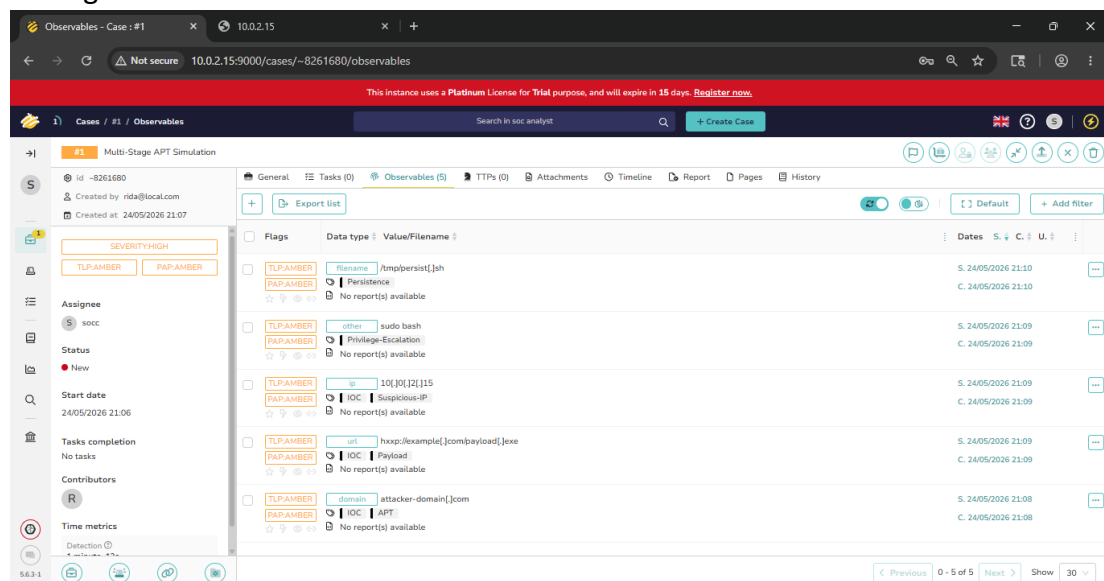
It mainly focuses on limiting or completely restricting command and control.

4. IOC monitoring

Identified IOCs including suspicious domains, IPs, commands, were shared across investigation platforms for future.

5. Case Escalation

The incident was marked as high severity and escalated within TheHive for case management.



5. Eradication

This section explains how the root cause was completely eliminated from the system after containment.

- **Persistence Removal**

The persistence mechanisms that were established during the attack simulation were identified and removed. This includes detected suspicious scheduled tasks and possible unauthorized accounts and artifacts that may still pose a chance for the attacker to gain entry.

- **Privileged Access Cleanup**

Privilege abuse identified during the investigation was addressed by removing the accounts and access pathways.

Credential review and host hardening were also performed to prevent repeated privilege escalation attempts.

- **Suspicious Artifacts Removal**

Suspicious scripts, IPs, domains etc. were completely blocked and removed to perform cleanup of the system to original state.

This also includes suspicious attacker behavioral indicators like unauthorized command execution, tools and techniques used by the attacker.

These are persistence artifacts identified for removal.

```
401 sudo docker compose up -d
402 sudo docker ps | grep misp-core
403 sudo docker compose up -d --no-deps misp-core
404 cd ~/misp-docker
405 sed -i '/CORE_HTTP_PORT/d' .env
406 sed -i '/CORE_HTTPS_PORT/d' .env
407 echo "CORE_HTTP_PORT=8081" >> .env
408 echo "CORE_HTTPS_PORT=8444" >> .env
409 sudo docker compose down
410 sudo docker compose up -d
411 sudo docker ps -a | grep modules
412 sudo docker compose up -d misp-core
413 sudo docker ps | grep misp-core
414 curl http://localhost
415 sudo docker port misp-docker-misp-core-1
416 curl http://localhost
417 sudo docker ps | grep misp-core
418 firefox
419 curl http://localhost:8081
420 sudo reboot
421 ip addr | grep inet
422 sudo firewall-cmd --permanent --add-port=8081/tcp
423 sudo firewall-cmd --permanent --add-port=8444/tcp
424 sudo ss -tulpn | grep 8081
425 sudo ss -tulpn | grep 8444
426 sudo docker logs misp-docker-misp-core-1 --tail 30
427 curl http://192.168.1.12:8081
428 curl -k https://localhost:8444
429 lsof -i :8444
430 sudo shutdown now
431 sudo so-status
432 sudo shutdown now
433 crontab -l
434 history
rshaikk@rshaikk ~]$ crontab -l
* * * * * /tmp/persist.sh
rshaikk@rshaikk ~]$ _
```

- **IOC Removal**

Extracted IOCs were marked as malicious and shared among investigation platforms and continuously monitored to ensure removal.

- **Monitoring Assets**

SOC monitoring tools were deployed to improve detection and alerting using IDPS fed with the latest attacks in the market and were kept active all the time to detect for any malicious artifacts still present in the system.

6. Recovery

This shows how the environment was restored back to its normal trusted operational state before the attack occurred, after eradication.

- 1) **System Integrity Validation**

Post-eradication was performed to test the presence of any malicious activity and ensuring that it no longer affects the system.

```

[rschaik@rschaikk ~]$ ss -tulpn

```

Netid	State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port	Process
udp	UNCONN	0	0	*:514	*:*	
udp	UNCONN	0	0	[fe80::a00:27ff:fed8:11e3]:enp0s3:546	:::*	
tcp	LISTEN	0	4096	0.0.0.0:6380	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:8086	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:8080	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:8081	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:7788	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:7789	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:5000	0.0.0.0:*	
tcp	LISTEN	0	1000	0.0.0.0:4505	0.0.0.0:*	
tcp	LISTEN	0	1000	0.0.0.0:4506	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:4433	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:4434	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.1:6789	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.1:6791	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:5601	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:9200	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:443	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:8444	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:8443	0.0.0.0:*	
tcp	LISTEN	0	128	0.0.0.0:22	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:80	0.0.0.0:*	
tcp	LISTEN	0	200	0.0.0.0:9992	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:9822	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:9300	0.0.0.0:*	
tcp	LISTEN	0	4096	*:27762	*:*	
tcp	LISTEN	0	4096	*:514	*:*	
tcp	LISTEN	0	128	:::22	:::*	

```

[rschaik@rschaikk ~]$

```

2) Security Monitoring Restoration

SOC tools like Security Onion, Wazuh, Kibana, Zeek and Suricata were kept active to improve the quality of monitoring and provide real-time event detection.

3) Credential Hardening

The access controls were strengthened by deploying MFA, account lockout, and role-based control to avoid privilege escalation according to the principle of least privilege.

4) Operations Recovery

Continuous validation of all the factors, host, system, network, communication to ensure that the system is now completely operational, free of malicious activity and safe for further activities with alongside real-time monitoring and detection.

7. Future Threat Prevention

1) Security Gaps Identified

Identifying security gaps is important to understand what exactly requires protection and detection in the future.

- weak access controls allowing privilege escalation, persistence mechanisms successful to the attacker.
- limited outbound traffic monitoring allowing suspicious HTTP/DNS communication and data transfer.
- ssh remote access increased risk of unauthorized lateral movement.
- lack of proactive threat detection and response thus delayed extraction of IOCs and the data transfer could not be stopped earlier.

2) Sigma Rules

A sigma rule is a generic detection rule that detects suspicious attacker behavior in logs.

Here is the list of created files that include sigma rules for the attack stages.

persistence.yml

privilege_escalation.yml

lateral_movement.yml

exfiltration.yml

```
lrshaik@rshaikk ~]$ ls
cortex-lab      lateral_movement.yml  privilege_escalation.yml  soc-stack
exfiltration.yml  misp-docker           Security0nion             thehive-lab
lateral         persistence.yml        sigma-rules               wazuh-agent-4.14.5-1.x86_64.rpm
lrshaik@rshaikk ~]$ _
```

Rule 1 — Persistence Detection

```
"persistence.yml" [New] 21L, 407B written
lrshaik@rshaikk ~]$ cat persistence.yml
title: Suspicious Persistence activity
id: 102
status: testing
description: detects cron command execution or persistence scripts created
author: rshaik
date: 2026-05-26
logsource:
  product: linux
  service: cron
detection:
  selection:
    message:
      - "cron"
      - "crontab"
      - "persist.sh"
      - "/tmp/persist.sh"
    condition: selection
level: high
tags:
  - attack.persistence
  - attack.t1053
lrshaik@rshaikk ~]$
```

This is the rule created in **persistence.yml** against persistence for future attacks through detection of **crontab** command execution containing cron/crontab/persist.sh/tmp/persist.sh in the message similar to the MITRE ATTACK T1053.

Rule 2 — Privilege Escalation Detection

```

"privilege_escalation.yml" 20L, 360B written
[rshaik@rshaikk ~]$ cat privilege_escalation.yml
title: Suspicious Privilege Escalation
id: 101
status: testing
description: detects sudo/root command execution
author: rshaik
date: 2026-05-26
logsource:
  product: linux
  service: auth
detection:
  selection:
    message:
      - "sudo"
      - "sudo bash"
      - "COMMAND="
  condition: selection
level: high
tags:
  - attack.privilege_escalation
  - attack.t1548
[rshaik@rshaikk ~]$ _

```

This is the rule created in **privilege_escalation.yml** against privilege escalation for future attacks through detection of **sudo/root** command execution containing sudo/sudo/COMMAND= in the message similar to the MITRE ATTACK T1548.

Rule 3 — Lateral Movement Detection

```

"lateral_movement.yml" [New] 20L, 382B written
[rshaik@rshaikk ~]$ cat lateral_movement.yml
title: Suspicious Lateral Movement detection
id: 103
status: testing
description: detects SSH authentication attempts
author: rshaik
date: 2026-05-26
logsource:
  product: linux
  service: sshd
detection:
  selection:
    message:
      - "Failed password"
      - "ssh"
      - "Invalid user"
  condition: selection
level: medium
tags:
  - attack.lateral_movement
  - attack.t1021
[rshaik@rshaikk ~]$

```

This is the rule created in **lateral_movement.yml** against lateral movement for future attacks through detection of **ssh** command execution containing Failed password/ssh/Invalid user in the message similar to the MITRE ATTACK T1021.

Rule 4 — Exfiltration Detection

```
"exfiltration.yml" [New] 24L, 467B written
[rshaik@rshaikk ~]$ cat exfiltration.yml
title: Suspicious exfiltration detection
id: 104
status: testing
description: detects DNS or HTTP outbound activity indicating exfiltration
author: rshaik
date: 2026-05-26
logsource:
  product: linux
  service: syslog
detection:
  selection:
    message:
      - "nslookup"
      - "dns"
      - "http"
      - "exfil-data"
      - "curl"
      - "attacker.com"
  condition: selection
level: high
tags:
  - attacker.exfiltration
  - attacker.t1048
  - attacker.t1041
[rshaik@rshaikk ~]$ _
```

This is the rule created in **exfiltration.yml** against exfiltration for future attacks through detection of **dns** command execution containing dns/nslookup/http/exfil-data/attacker.com/curl in the message similar to the MITRE ATTACK T1048/T1041.

3) YARA Rules

YARA – Yet Another Recursive Acronym

It is a rule-based malware detection rule that detects suspicious patterns and IOCs from files, memory and system.

```
[rshaik@rshaikk ~]$ ls
apt_detection.yar  lateral_movement.yml  SecurityOnion  wazuh-agent-4.14.5-1.x86_64.rpm
```

Rules created against the attack stages as part of future prevention in **apt_detection.yar**

```

rule persistence
{
    meta:
        description = "detects cron-based persistence"
        author: "rshaik"

    strings:
        $a = "/tmp/persist.sh"
        $b = "crontab"
        $c = "* * * * *"

    condition:
        any of them
}

rule privilege_escalation
{
    meta:
        description = "detects sudo command execution"
        author = "rshaik"

    strings:
        $a = "sudo bash"
        $b = "sudo"
        $c = "root"

    condition:
        any of them
}

```

```

rule lateral_movement
{
    meta:
        description = "detects ssh activities"
        author: "rshaik"

    strings:
        $a = "ssh"
        $b = "Invalid user"
        $c = "Failed password"

    condition:
        any of them
}

rule exfiltration
{
    meta:
        description = "detects DNS/HTTP exfiltration"
        author: "rshaik"

    strings:
        $a = "dns"
        $b = "exfil-data"
        $c = "attacker.com"
        $d = "nslookup"
        $e = "curl"

    condition:
        any of them
}

rule multistage_aptattack

```

```

rule multistage_aptattack

meta:
    description = "combined attacker patterns"
    author = "rshaik"

strings:
    $a = "ssh"
    $b = "cron"
    $c = "sudo"
    $d = "dns"

condition:
    3 of them

```

4) MISP Threat Intelligence Sharing

The extracted IOCs were documented and shared in Malware Information Sharing Platform (MISP).

This improves faster identification of threats in the future to readily detect them that are previously observed.

The documented threat intelligence IOCs are associated with initial access, persistence, privilege escalation, lateral movement and exfiltration.

Threat intelligence through MISP supports –

- Proactive IOC correlation
- Improved threat detection
- Faster incident response
- Shared analysts' awareness
- Enhanced threat hunting

The screenshot displays the MISP web interface. On the left, the 'PROJECT STAGES' section shows a progress bar for five stages: Environment Setup, Security Onion installation, MISP installation (Docker), Configuration & Integration, and Testing & Verification. Below this, 'DEPLOYMENT INFO' lists project details like name, date, environment, and version.

The main 'Dashboard' area provides an overview of the threat intelligence platform with several key metrics: 3 My Events, 0 My Organization Events, 3 Global Events, 1 My Galaxies, 0 My Organisation Galaxies, and 1 Global Galaxies. Below these are tables for 'My Events' and 'Global Events', each showing columns for Date, Threat Level, Analysis, Info (ATT&CK Stages), and #Attributes.

At the bottom, the 'All Events' section lists all events in the system, including columns for Date, Threat Level, Analysis, Info (ATT&CK Stages), Published status, #Attributes, and Actions. The interface also includes a search bar and tabs for 'Index View' and 'Graph View'.

8. Mitigation Plan

- **Strengthen Privilege Access Control** - enforce policies like least privilege rule and role-based access controls, implement MFA, restrict unnecessary permissions.
- **Enhance Persistence Monitoring** - perform continuous real-time event monitoring, scheduled tasks, cron jobs and unauthorized persistence scripts.
- **Improve Host-level Monitoring** - improve endpoint detection and response, enhanced log collection and suspicious process detection.
- **Improve Network-level Monitoring** - monitor incoming and outgoing traffic, for suspicious DNS/HTTP communication and block if it meets the threshold.
- **Hardening Assets** - harden credentials, SSH configurations, unused remote services and authentication auditing.
- **Deploy Proactive Detection Rules** - integrate Sigma rules to detect suspicious attacker behaviour and YARA rules to detect suspicious attack patterns and IOCs.

9. Lessons Learned

- Early detection through security monitoring may have stopped the attack at initial stages and not prolong until data exfiltration.
- Correlation between network and host-based monitoring allows stronger attack visibility and detection.
- Multi-stage attacks require layered defence and monitoring as one security control cannot detect the whole process.
- Structured case management through TheHive enhances detection, investigation and documentation workflow.
- Privilege abuse may lead to a great loss for a real attack financially and reputationally if not proactively controlled.
- Regular development and deployment of rules like sigma and YARA with the latest attacks and its IOCs allows long-term safety to the organizations against similar threats.

10. Conclusion

The incident response activity successfully demonstrated the detection, investigation, containment, recovery, lessons learned and future threat prevention mechanisms for the simulated multi-stage APT attack.

SOC monitoring tools like Security Onion, Wazuh, Kibana, Zeek and Suricata identified the attack stages and gave alerts. TheHive & Cortex supported in the structured investigation and observable analysis. Threat Intelligence by sharing the extracted IOCs with MISP helps in future proactive threat hunt and prevention and detection rules like Sigma and YARA were developed as preventive measures in the future against similar attacks.

Overall, it demonstrated a structured incident response workflow aligned with SOC tools and prepared against similar cyber-attacks in real-world environments in the future.